

Scansione finale di Metasploitable 2

Confronto dopo gli interventi su quattro criticità

Martina Foresta | CyberSecurity | 4 ottobre 2026

Ho ripetuto la scansione di 192.168.50.101 dopo gli interventi descritti nel report RemediationMeta. Il risultato finale non riporta più le quattro segnalazioni che avevo scelto nella scansione iniziale. Questa osservazione non significa che Metasploitable 2 sia diventata sicura: nella nuova scansione restano due voci Critical e altre esposizioni.

Nel riquadro Vulnerabilities Nessus mostrava 87 voci il 29 settembre 2026 e ne mostra 66 nella scansione conclusiva del 4 ottobre 2026. Il numero comprende anche risultati informativi e può variare in base alla copertura della scansione: non lo interpreto come 21 vulnerabilità corrette.

Finding iniziale	Porta	Verifica finale	Limite dell'esito
Bind Shell Backdoor Detection - 51988	1524/tcp	Ricerca 0/66; porta closed	La chiusura dipende dalla configurazione del servizio.
VNC Server 'password' Password - 61708	5900/tcp	La voce Critical non appare; gruppo VNC solo Info	VNC resta open e la comunicazione non è cifrata.
Ghostcat AJP - 134862	8009/tcp	Ricerca 0/66; porta closed	Il connettore AJP è stato disabilitato.
SSL Version 2 and 3 - 20007	25 e 5432/tcp	Ricerca 0/66; porte filtered	Il filtro è temporaneo; SSLv2/SSLv3 non sono stati disabilitati nei servizi.

La tabella riassume ciò che ho potuto verificare. Le pagine successive riportano gli screenshot originali prima e dopo; il secondo report documenta i singoli interventi.

Punto di partenza

Nella scansione iniziale del 29 settembre 2026, Nessus mostrava 87 voci per l'host 192.168.50.101. Le quattro segnalazioni scelte erano tutte classificate Critical nell'elenco: bind shell, password VNC predefinita, Ghostcat sul connettore AJP e rilevamento di SSLv2/SSLv3.

La verifica Nmap iniziale mostrava aperte le porte 25, 1524, 5432, 5900 e 8009. I dettagli dei plugin Nessus fornivano la prova specifica delle segnalazioni.

tenable

Nessus Essentials

Scans

Settings

?

martina

FOLDERS

My Scans

Epicode

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Metasploitable 2 / 192.168.50.101

Configure

Audit Trail

Launch

Report

Export

Vulnerabilities

87

Filter

Search Vulnerabilities

87 Vulnerabilities

☐	Sev	CVSS	VPR	EPSS	Name	Family	Count		
☐	CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1		
☐	CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1		
☐	CRITICAL	9.8	7.9	0.9927	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1		
☐	CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2		
☐	CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1		
☐	MIXED	...	...	...	Phpmyadmin (Multiple Issues)	CGI abuses	4		
☐	CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3		
☐	MIXED	...	...	...	PHP (Multiple Issues)	CGI abuses	3		
☐	HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1		
☐	HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1		
☐	HIGH	7.5			NFS Shares World Readable	RPC	1		

Host Details

IP:

192.168.50.101

MAC:

08:00:27:25:91:4C

OS:

Linux Kernel 2.6 on Ubuntu 8.04 (hardy)

Start:

September 29 at 2:33 PM

End:

September 29 at 3:09 PM

Elapsed:

35 minutes

KB:

[Download](#)

Auth:

Fail

Vulnerabilities

Critical

High

Medium

Low

Info

1 Bind shell prima dell'intervento

Il plugin Nessus 51988 identificava una shell raggiungibile sulla porta 1524/tcp senza autenticazione. Nell'output della scansione, l'esecuzione di id restituiva uid=0(root), gid=0(root): era una prova concreta dell'accesso privilegiato, non soltanto della porta aperta.

Nel sistema di laboratorio la voce ingreslock in /etc/inetd.conf avviava /bin/bash. Ho commentato la riga e riavviato xinetd, che risultava il processo in ascolto sulla porta. Il comando e la verifica del servizio sono riportati nel report di remediation.

The screenshot displays the Tenable Nessus Essentials interface. The left sidebar shows the navigation menu with 'FOLDERS' (My Scans, Epicode, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main content area is titled 'Metasploitable 2 / Plugin #51988' and shows a 'Vulnerabilities' count of 87. The selected vulnerability is 'Bind Shell Backdoor Detection', marked as 'CRITICAL'. The description states: 'A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.' The solution advises: 'Verify if the remote host has been compromised, and reinstall the system if necessary.' The output section shows a truncated command prompt output: 'root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)'. The right sidebar provides 'Plugin Details' (Severity: Critical, ID: 51988, Version: 1.10, Type: remote, Family: Backdoors, Published: February 15, 2011, Modified: April 11, 2022) and 'Risk Information' (Risk Factor: Critical, CVSS v3.0 Base Score: 9.8, CVSS v2.0 Base Score: 10.0).

tenable Nessus Essentials Scans Settings

My Scans Epicode All Scans Trash

Policies Plugin Rules

Metasploitable 2 / Plugin #51988

Configure Audit Trail Launch Report Export

Vulnerabilities 87

CRITICAL Bind Shell Backdoor Detection

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

Nessus was able to execute the command "id" using the following request :

This produced the following truncated output (limited to 10 lines) :

```
..... snip .....
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
..... snip .....
```

To see debug logs, please visit individual host

Port **Hosts**

1524 / tcp / wild_shell 192.168.50.101

Plugin Details

Severity: Critical
ID: 51988
Version: 1.10
Type: remote
Family: Backdoors
Published: February 15, 2011
Modified: April 11, 2022

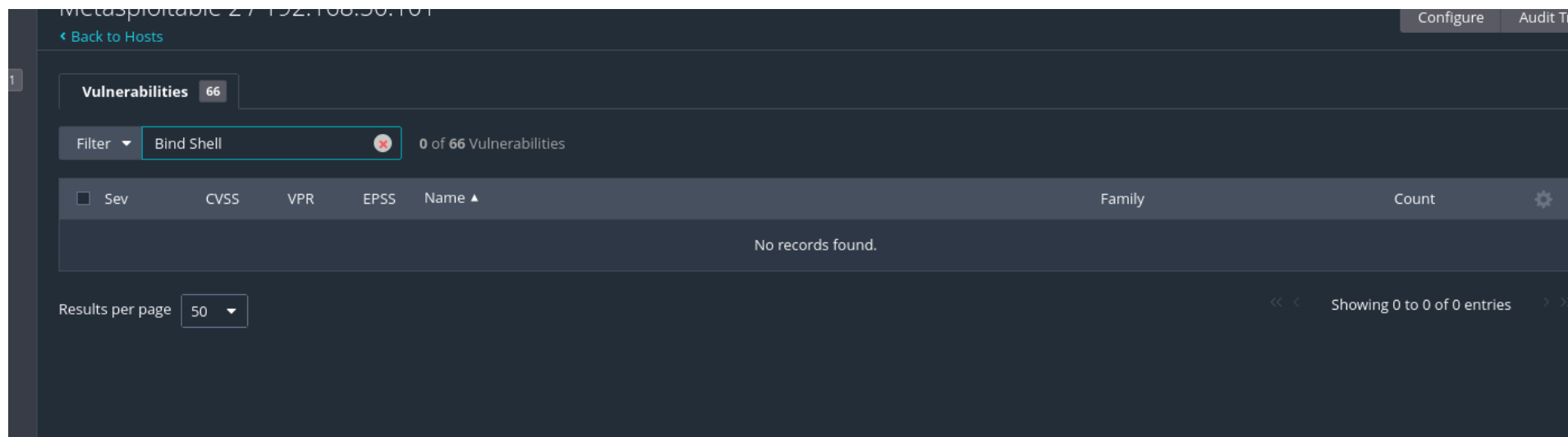
Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:I/I:C/A:C

1 Bind shell dopo l'intervento

Nella scansione conclusiva, la ricerca Bind Shell dà 0 risultati su 66. Il controllo Nmap eseguito da Kali mostra 1524/tcp closed. I due riscontri sono coerenti: il servizio non accetta più connessioni sulla porta che espose la shell.

Registro l'esito come rimozione dell'esposizione osservata in questo laboratorio. Se la configurazione venisse ripristinata o un altro servizio riaprisse la porta, sarebbe necessaria una nuova verifica.



2 VNC prima dell'intervento

Il plugin 61708 segnalava che il server VNC sulla porta 5900/tcp accettava la password predefinita password. Nell'output della scansione Nessus dichiarava esplicitamente di avere effettuato l'accesso con quella credenziale. La debolezza riguardava quindi l'autenticazione, non la sola presenza di VNC.

Ho cambiato la password con vncpasswd. Durante la prova successiva, la vecchia password è stata rifiutata e la nuova ha permesso l'accesso. Nel secondo report ho conservato gli screenshot di questo passaggio.

The screenshot displays the Tenable Nessus Essentials interface. The left sidebar shows the navigation menu with 'FOLDERS' (My Scans, Epicode, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main content area is titled 'Metasploitable 2 / Plugin #61708' and includes buttons for 'Configure', 'Audit Trail', 'Launch', 'Report', and 'Export'. A 'Vulnerabilities' tab shows 87 items, with the first one highlighted: 'VNC Server 'password' Password' (CRITICAL). The details for this vulnerability are shown on the right, including a description, solution, output, and plugin details.

Vulnerabilities 87

CRITICAL VNC Server 'password' Password

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution
Secure the VNC service with a strong password.

Output

Nessus logged in using a password of "password".

To see debug logs, please visit individual host

Port	Hosts
5900 / tcp / vnc	192.168.50.101

Plugin Details

Severity: Critical
ID: 61708
Version: \$Revision: 1.2 \$
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 24, 2015

Risk Information

Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:I/I:C/A:C

Vulnerability Information

Default Account: true
Exploited by Nessus: true

2 VNC dopo l'intervento

Nell'elenco finale ordinato per gravità non compare più la voce Critical sulla password predefinita. Il gruppo VNC esaminato contiene tre voci Info: tipo di sicurezza, comunicazione non cifrata e rilevamento del software. Questo è coerente con il cambio della password, ma non equivale a una protezione completa del servizio.

La porta 5900/tcp resta open e Nessus segnala che VNC comunica senza cifratura.

The screenshot displays the Tenable Nessus Essentials interface. The main header shows 'tenable Nessus Essentials' with tabs for 'Scans' and 'Settings'. The user 'martina' is logged in. The left sidebar contains 'FOLDERS' (My Scans, Epicode, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main content area is titled 'Metasploitable 2 / 192.168.50.101 / VNC (Multiple Issues)' and includes buttons for 'Configure', 'Audit Trail', 'Launch', 'Report', and 'Export'. Below the title, a 'Vulnerabilities' section shows '66' total vulnerabilities, with a search bar and '3 Vulnerabilities' displayed. A table lists the following vulnerabilities:

Sev	CVSS	VPR	EPSS	Name	Family	Count	
INFO				VNC Server Security Type Detection	Service detection	1	
INFO				VNC Server Unencrypted Communication Detection	Service detection	1	
INFO				VNC Software Detection	Service detection	1	

On the right, 'Scan Details' are provided: Policy: Basic Network Scan, Status: Completed, Severity Base: CVSS v3.0, Scanner: Local Scanner, Start: Today at 8:19 PM, End: Today at 9:05 PM, Elapsed: an hour. Below this, a 'Vulnerabilities' donut chart shows the distribution: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue). The chart is predominantly blue, indicating that most vulnerabilities are of Info severity.

3 Ghostcat prima dell'intervento

La scansione iniziale riportava Apache Tomcat AJP Connector Request Injection, noto come Ghostcat, sulla porta 8009/tcp. Il risultato era etichettato Critical nell'elenco Nessus; nella pagina di dettaglio il campo Risk Factor riportava High.

Il connettore AJP era attivo nel file server.xml di Tomcat 5.5. Poiché non serviva nell'esercizio, ho rimosso la definizione del connettore e riavviato Tomcat, controllando poi che il servizio principale fosse avviato.

tenable

Nessus Essentials

Scans

Settings

My Scans

Epicode

All Scans

Trash

Policies

Plugin Rules

Metasploitable 2 / Plugin #134862

Configure

Audit Trail

Launch

Report

Export

Vulnerabilities 87

CRITICAL

Apache Tomcat AJP Connector Request Injection (Ghostcat)

Description

A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

Solution

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

See Also

<http://www.nessus.org/u?8ebe6246>
<http://www.nessus.org/u?4e287adb>
<http://www.nessus.org/u?cb3d54e>
<https://access.redhat.com/security/cve/CVE-2020-1745>
<https://access.redhat.com/solutions/4851251>
<http://www.nessus.org/u?dd218234>
<http://www.nessus.org/u?dd772531>
<http://www.nessus.org/u?2a01d6bf>
<http://www.nessus.org/u?3b5af27e>
<http://www.nessus.org/u?9dab109f>
<http://www.nessus.org/u?5eafcf70>

Output

Nessus was able to exploit the issue using the following request :

Severity: Critical

ID: 134862

Version: 1.64

Type: remote

Family: Web Servers

Published: March 24, 2020

Modified: August 10, 2026

VPR Key Drivers

Threat Recency: No recorded events

Threat Intensity: Very Low

Exploit Code Maturity: High

Age of Vuln: 730 days +

Product Coverage: Very High

CVSSv3 Impact Score: 5.9

Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 7.9

Exploit Prediction Scoring System (EPSS): 0.9927

Risk Factor: High

CVSS v3.0 Base Score: 9.8

3 Ghostcat dopo l'intervento

La ricerca Ghostcat nella scansione conclusiva restituisce 0 risultati su 66. Da Kali, Nmap indica 8009/tcp closed. La porta del connettore AJP non è più raggiungibile e la segnalazione non compare nella nuova scansione.

Questa verifica sostiene l'efficacia della disattivazione del connettore nell'assetto attuale. Non dimostra che ogni componente della vecchia installazione Tomcat sia aggiornato o privo di altri difetti.

The screenshot shows the Tenable Nessus Essentials interface. The main header displays 'Metasploitable 2 / 192.168.50.101'. Below this, the 'Vulnerabilities' section shows a filter for 'Ghostcat' with 0 of 66 vulnerabilities found. The table below the filter is empty, displaying 'No records found.' The right sidebar contains 'Host Details' and a 'Vulnerabilities' donut chart.

Host Details

- IP: 192.168.50.101
- MAC: 08:00:27:25:91:4C
- OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
- Start: Today at 8:19 PM
- End: Today at 9:05 PM
- Elapsed: an hour
- KB: [Download](#)
- Auth: Fail

Vulnerabilities

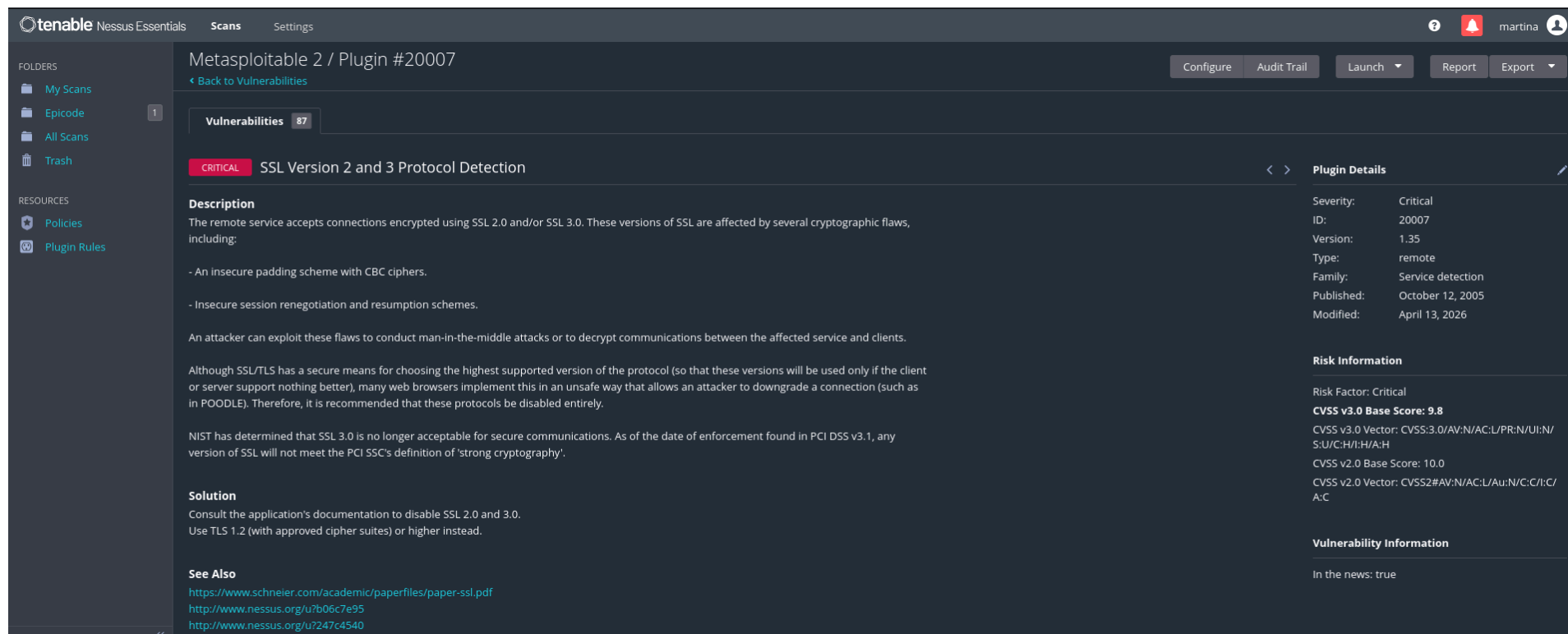
Donut chart showing the distribution of vulnerability severity levels:

- Critical (Red)
- High (Orange)
- Medium (Yellow)
- Low (Green)
- Info (Blue)

4 SSLv2 e SSLv3 prima dell'intervento

Il plugin 20007 segnalava SSL Version 2 and 3 Protocol Detection su due istanze: SMTP alla porta 25/tcp e PostgreSQL alla 5432/tcp. Il problema riguardava l'accettazione di protocolli crittografici obsoleti da parte dei servizi raggiungibili.

In questa esercitazione non ho modificato le configurazioni dei due servizi. Ho aggiunto due regole iptables per bloccare temporaneamente dall'esterno l'accesso alle porte 25 e 5432. Il controllo Nmap precedente alla scansione le mostrava filtered.

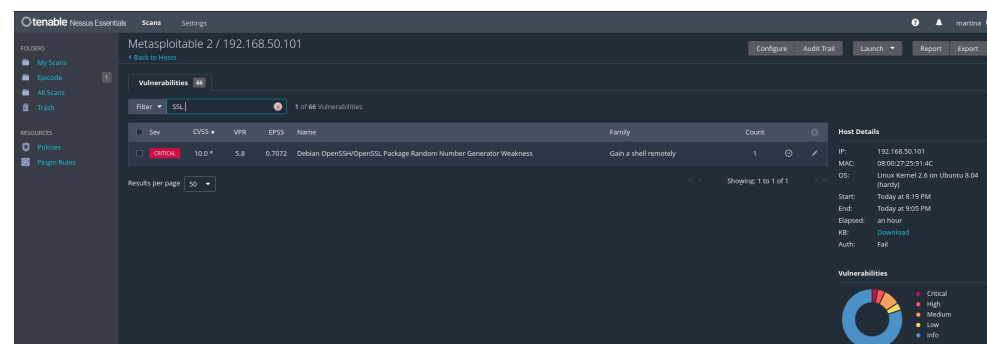
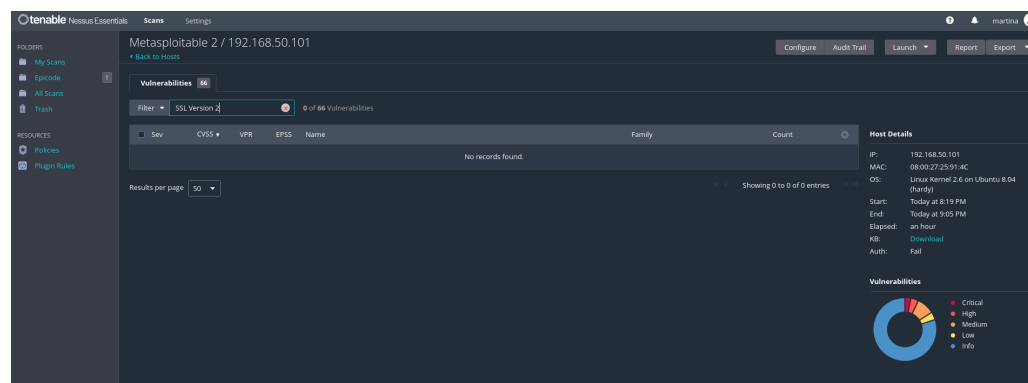


The screenshot displays the Tenable Nessus Essentials interface. The top navigation bar shows 'tenable Nessus Essentials', 'Scans', and 'Settings'. The user 'martina' is logged in. The left sidebar contains 'FOLDERS' (My Scans, Epicode, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main content area is titled 'Metasploitable 2 / Plugin #20007' and shows a 'Vulnerabilities' count of 87. The selected vulnerability is 'SSL Version 2 and 3 Protocol Detection', marked as 'CRITICAL'. The description states that the remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0, which are affected by cryptographic flaws. The solution advises consulting the application's documentation to disable SSL 2.0 and 3.0, and using TLS 1.2 or higher. The right-hand panel provides 'Plugin Details' (Severity: Critical, ID: 20007, Version: 1.35, Type: remote, Family: Service detection, Published: October 12, 2005, Modified: April 13, 2026) and 'Risk Information' (Risk Factor: Critical, CVSS v3.0 Base Score: 9.8, CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H, CVSS v2.0 Base Score: 10.0, CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:I/C/A:C). The 'Vulnerability Information' section shows 'In the news: true'.

4 SSLv2 e SSLv3 dopo l'intervento

La ricerca SSL Version 2 nella scansione finale non trova risultati. Cercando SSL in modo più ampio compare una sola voce, relativa a Debian OpenSSH/OpenSSL Package Random Number Generator Weakness: è una criticità diversa dal plugin 20007.

Questo non prova che SMTP e PostgreSQL abbiano smesso di supportare SSLv2 o SSLv3: le porte filtrate impediscono a Nessus di controllarli.



Risultato complessivo della scansione finale

La scansione conclusiva da 66 voci, mostra ancora due risultati Critical nella parte alta dell'elenco: Debian OpenSSH/OpenSSL Package Random Number Generator Weakness e Canonical Ubuntu Linux SEoL (8.04.x). Sono problemi diversi dai quattro oggetto dell'intervento, ma impediscono di dichiarare l'host risanato nel complesso.

Il confronto 87→66 descrive i due riepiloghi di Nessus, non misura da solo il numero di vulnerabilità eliminate. La scansione finale è priva di autenticazione riuscita (Auth: Fail); inoltre le porte filtrate possono sottrarre servizi alla verifica.

The screenshot shows the Tenable Nessus Essentials interface. The main header indicates the scan is for 'Metasploitable 2 / 192.168.50.101'. The left sidebar shows the 'FOLDERS' section with 'My Scans', 'Epicode', 'All Scans', and 'Trash'. The 'RESOURCES' section includes 'Policies' and 'Plugin Rules'. The main content area displays a table of 'Vulnerabilities' with 66 items. The table columns are: Sev, CVSS, VPR, EPSS, Name, Family, Count, and a settings icon. The vulnerabilities are listed in descending order of severity. The right sidebar shows 'Host Details' for the scanned host, including IP, MAC, OS, Start/End times, Elapsed time, KB, and Auth status. Below the host details is a 'Vulnerabilities' section with a donut chart showing the distribution of severity levels: Critical (red), High (orange), Medium (yellow), Low (blue), and Info (light blue).

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0 *	5.8	0.7072	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness	Gain a shell remotely	1
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1
HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1
HIGH	7.5			NFS Shares World Readable	RPC	1
MEDIUM	5.3			Browsable Web Directories	CGI abuses	1
MEDIUM	5.0 *			Backup Files Disclosure	CGI abuses	1
MEDIUM	4.3 *			Web Application Potentially Vulnerable to Clickjacking	Web Servers	1
LOW	2.6 *			X Server Detection	Service detection	1
LOW	2.1 *	3.2	0.3215	ICMP Timestamp Request Remote Date Disclosure	General	1
MIXED	...	...	...	Phpmyadmin (Multiple Issues)	CGI abuses	4
MIXED	...	...	...	PHP (Multiple Issues)	CGI abuses	3

Verifica delle porte e conclusioni

Il confronto Nmap mostra le cinque porte aperte prima e, dopo gli interventi, 1524 e 8009 closed, 25 e 5432 filtered, 5900 open. Closed indica che non risponde un servizio; filtered che il filtro impedisce la verifica; open che il servizio resta raggiungibile.

La bind shell e l'esposizione AJP sono state chiuse nel laboratorio; la password VNC predefinita è stata sostituita, ma VNC resta attivo e non cifrato; per SSLv2/SSLv3 ho applicato solo una mitigazione temporanea.

```
(kali@kali)-[~]
$ nmap -sV -p 1524,5900,8009,25,5432 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 13:26 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0043s latency).

PORT      STATE SERVICE      VERSION
25/tcp    open  smtp         Postfix smtpd
1524/tcp  open  bindshell    Metasploitable root shell
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.14 seconds
```

```
Session Actions Edit View Help
(kali@kali)-[~]
$ nmap -p 25,5432,8009,1524,5900 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 21:51 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0022s latency).

PORT      STATE SERVICE
25/tcp    filtered smtp
1524/tcp  closed  ingreslock
5432/tcp  filtered postgresql
5900/tcp  open    vnc
8009/tcp  closed  ajp13
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)
```